

Revision de playbooks con mejoras

Divier Jácamo Álvarez

Cetav la Libertad

Rol: Analista SOC L1

Fecha viernes 27/02/26

## Revisión de playbooks del SOC L2

Al analizar los trabajos de karen que es la SOC L2 di con la siguiente conclusión

El analisis de los procesos para detectar ransomware y accesos sospechosos resalta la necesidad de adoptar un enfoque estructurado en la gestión de incidentes en un entorno de SOC L2 los eventos de seguridad, como el ransomware, exigen una identificación temprana efectiva y una respuesta organizada, especialmente dado que los ataques están evolucionando y volviéndose más complejos.

La conexión de eventos mediante herramientas como SIEM y EDR es fundamental para reconocer patrones de comportamiento anómalos que puedan señalar una posible infección, tal como la creación masiva de archivos o cambios en los mismos.

Un SOC L2 debe establecer procedimientos claros que faciliten una respuesta rápida y adecuada, incluyendo la validación técnica del incidente a través del análisis de registros y la utilización de instrumentos de análisis dinámico, como sandbox.

Estas herramientas permiten monitorizar el comportamiento del malware y obtener

indicadores cruciales que son útiles para identificar la variante de ransomware y sus métodos de evasión, como el uso de PowerShell para ejecutar código malicioso.

Además, es esencial contar con protocolos definidos para la contención de incidentes acciones como el aislamiento inmediato de equipos infectados, la restricción de IPs maliciosas y la protección de copias de seguridad son vitales para detener la propagación del ataque y minimizar el daño en esta etapa, la preservación de pruebas es fundamental para las investigaciones forenses posteriores.

Finalmente, la recuperación tras un incidente debe llevarse a cabo con precaución comprobar la integridad de las copias de seguridad antes de su restauración y aplicar vigilancia intensiva son pasos críticos para prevenir una reinfección el examen de la causa raíz, la rotación de contraseñas y la actualización de parches son fundamentales para fortalecer las defensas y evitar futuros ataques.

## Mejoras derivadas de revisión

Tras un examen minucioso de los procedimientos destinados a la detección y respuesta frente a incidentes de ransomware y accesos sospechosos, se han identificado varias áreas que requieren mejora para optimizar la efectividad de las estrategias de seguridad y respuesta, que son las siguientes:

### 1. Mejora en la Detección Temprana

**Automatización y Ajuste de Reglas en SIEM/EDR:** Es crucial invertir en la automatización de la detección para generar alertas más precisas.

Modificar las reglas de correlación de eventos en el SIEM podría potenciar la identificación de patrones de ransomware, como comportamientos de cifrado o utilización de PowerShell maliciosa.

La incorporación de inteligencia artificial y aprendizaje automático en estos sistemas facilitaría una detección más temprana de amenazas, incluso aquellas que son desconocidas.

**Implementación de Honeypots:** El uso de honeypots para identificar movimientos laterales o intentos de acceso no autorizado a segmentos específicos de la red podría aumentar la

visibilidad sobre los atacantes dentro de la infraestructura.

## 2. Análisis Forense Mejorado

Mejora en el Análisis Dinámico: Aunque herramientas como Any.Run o Joe Sandbox son útiles, se podría añadir análisis dinámico en múltiples plataformas para abarcar no solo sistemas Windows, sino también entornos de contenedores o sistemas en la nube, que se han convertido en objetivos comunes de los atacantes.

Mejoras en la Preservación de Evidencia: Durante la fase de contención, es esencial garantizar la preservación completa de la evidencia, por lo que es necesario automatizar los procesos de captura de imágenes de memoria y registros de eventos, además de establecer políticas claras para asegurar la cadena de custodia. Implementar soluciones de respaldo inmutable también aseguraría la protección de datos clave para la recuperación.

## 3. Respuesta a la Contención y Mitigación

Segmentación Avanzada de Red: Para prevenir la propagación lateral, se aconseja aplicar segmentación dinámica mediante microsegmentación en la red, lo que permitirá el aislamiento incluso dentro de los mismos segmentos. Además, se debe fortalecer el control de acceso basado en identidad para garantizar que solo los usuarios con permisos adecuados

accedan a áreas críticas.

**Automatización en la Contención:** La rapidez de la respuesta podría ser mejorada mediante playbooks automatizadas utilizando soluciones SOAR, lo que permitiría que los sistemas de seguridad reaccionen automáticamente ante eventos sospechosos, como el aislamiento de un endpoint o el bloqueo de una IP, sin requerir intervención manual.

#### 4. Fortalecimiento de la Recuperación

**Validación de Backups en Tiempo Real:** Con el fin de prevenir que los backups sean comprometedores, se sugiere implementar soluciones de respaldo en la nube con acceso restringido y validaciones de integridad periódicas. Adoptar una estrategia de backup también podría ofrecer una capa adicional de protección.

**Pruebas de Recuperación Automatizadas:** Las pruebas para restaurar backups deben ser automatizadas y realizarse más frecuentemente, preferiblemente en un entorno de pruebas que no interrumpa las operaciones habituales, para asegurar la agilidad y efectividad de la recuperación posterior a un ataque.

#### 5. Mejora en la Formación y Concientización

**Capacitación Continua para el Personal:** Es vital que tanto el personal técnico como los

usuarios finales reciban formación constante sobre las últimas tácticas y amenazas relacionadas con el ransomware.

Los ejercicios de simulación de phishing realizados de forma regular pueden contribuir a disminuir el riesgo de que los empleados se vean atrapados en ataques de phishing, que continúa siendo uno de los métodos de acceso más frecuentes.

Reducción de la Exposición a Amenazas: La aplicación del principio de menor privilegio en toda la infraestructura, junto con la implementación de autenticación multifactor en todos los accesos críticos, reducirá considerablemente la posibilidad de que un atacante obtenga acceso a través de credenciales comprometidas.

## 6. Optimización de la Comunicación Después de un Incidente

Mejor Organización entre Grupos: La gestión de incidentes debe contemplar una mejor colaboración entre el equipo de SOC, el departamento de TI y el área legal, lo cual es especialmente crucial al tratar con información sensible, ya que un ataque puede implicar la exfiltración de datos y la necesidad de cumplir con informes regulatorios.

Informe Detallado Post-Incidente: Después de un ataque, el informe post-incidente debe contener no solo un resumen ejecutivo, sino también una cronología detallada del suceso, un

análisis de la causa raíz y sugerencias concretas para prevenir ataques futuros.

La implementación de estas mejoras no solo aumentará la efectividad en la detección y respuesta a un ataque de ransomware, sino que también fortalecerá las defensas de la organización a largo plazo la automatización, la segmentación avanzada de la red y un análisis forense mejorado son pasos críticos para perfeccionar la capacidad de un SOC L2 y aumentar la resiliencia frente a incidentes. Además, la formación continua, la validación de copias de seguridad y el uso de MFA disminuirán significativamente la probabilidad de éxito de un ataque, asegurando una recuperación más ágil y con menor impacto sobre la organización.

### Documentación final

En la respuesta a incidentes relacionados con ransomware y accesos sospechosos, es crucial adoptar un enfoque bien organizado y detallado para asegurar la detección temprana, la reducción de daños y la recuperación eficaz analizando los procedimientos anteriores, es posible identificar diversas áreas clave donde se pueden realizar mejoras para optimizar la respuesta de un SOC L2 estas optimizaciones buscan potenciar las capacidades de detección, afinar la respuesta ante incidentes, fortalecer la recuperación y asegurar una protección continua de la infraestructura de la organización.



## 1. Optimización de la Detección Temprana

La utilización de herramientas SIEM y EDR para detectar ransomware debe ser tanto automática como efectiva las reglas de correlación de eventos en el SIEM pueden ser ajustadas y perfeccionadas para detectar comportamientos anómalos, como aumentos inusuales en la escritura de archivos o ejecuciones no autorizadas a través de PowerShell la automatización en la detección mediante tecnologías de inteligencia artificial y aprendizaje automático podría facilitar el reconocimiento de comportamientos desconocidos además, la implementación de honeypots permitiría identificar de manera más precisa accesos no autorizados o movimientos laterales dentro de la red.

## 2. Mejora en el Análisis Forense

El estudio de malware debe abarcar tanto el análisis estático como el dinámico. Utilizar herramientas avanzadas como el sandboxing para realizar análisis en tiempo real permitirá observar cómo se comporta el ransomware y sus interacciones con redes externas asimismo, para hacer frente a ataques más sofisticados, es necesario fortalecer la capacidad de analizar sistemas no convencionales, como contenedores y entornos en la nube también se debe mejorar la preservación de la evidencia durante la contención, asegurando que las imágenes de memoria volátil y los registros de eventos se capturen de manera correcta, respetando un proceso de cadena de custodia.

### 3. Respuesta a la Contención y Mitigación

Para contener un ataque de ransomware, se aconseja implementar microsegmentación en la red, lo que permite aislar incluso dentro de los mismos segmentos y proteger los activos crítico la automatización de playbooks mediante soluciones SOAR permitirá al sistema reaccionar ante incidentes de forma automática, sin necesidad de intervención manual, lo que disminuirá el tiempo de respuesta ante un ataque.

### 4. Fortalecimiento de la Recuperación

La recuperación tras un ataque de ransomware debe incluir un control de integridad de los respaldos utilizando backups inmutables esto asegurará que los respaldos no se comprometan y que la infraestructura afectada pueda ser restaurada de manera segura además, la implementación de pruebas automatizadas de restauración de backups garantizará que los datos estén disponibles y sean confiables antes de ser restaurados al entorno de producción.

### 5. Mejora en la Formación y Concientización

La formación continua de los trabajadores es crucial para disminuir los riesgos asociados a ataques de phishing, que son uno de los métodos más frecuentes para la infiltración de malware la realización de simulaciones de phishing de forma regular y la educación sobre las últimas estrategias de ransomware fortalecerán la seguridad de la organización también es

vital aplicar el principio de mínimo privilegio con rigurosidad para reducir el impacto si las credenciales de los usuarios llegan a verse comprometidas.

## 6. Mejora en la Comunicación Post-Incidente

Una coordinación eficiente entre los equipos de SOC, TI y las áreas legales es esencial para gestionar adecuadamente la comunicación tras un incidente de ransomware asegurar que todos los involucrados entiendan claramente el incidente y sus consecuencias contribuye a disminuir el riesgo de daños adicionales además, un informe después del incidente debe incluir una cronología detallada del ataque, un análisis de las causas y recomendaciones específicas para prevenir nuevos incidentes.

## Conclusión

Implementar estas mejoras sistemáticas en cada etapa de detección, contención, análisis y recuperación permitirá a las organizaciones mejorar su capacidad de respuesta ante ataques de ransomware y accesos sospechosos la automatización, la segmentación avanzada de la red y la formación continua son elementos clave para incrementar la eficacia operativa de un SOC L2 igualmente, la preservación de evidencia y un análisis forense más riguroso proporcionarán una comprensión profunda de los ataques, ayudando a prevenir futuros incidentes y a fortalecer las defensas generales de la organización.

## Referencias

National Institute of Standards and Technology. (2021). *NIST Special Publication 800-61 Revision 2: Computer Security Incident Handling Guide*. National Institute of Standards and Technology.

<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf>

SANS Institute. (2020). *Incident response: Handling cybersecurity incidents*. SANS Institute.

<https://www.sans.org/cyber-security-courses/incident-response-handling/>

Microsoft. (2021). *How to prevent, detect, and respond to ransomware attacks*.

<https://www.microsoft.com/security/blog/2021/02/01/how-to-prevent-detect-and-respond-to-ransomware-attacks/>

ESET. (2020). *What is ransomware and how to protect your organization*.

<https://www.eset.com/us/business/ransomware/>